



Informe Final — Laboratorio SOC: Investigación y Respuesta ante Fuerza Bruta SSH con Wazuh

Detección, análisis y hardening de un ataque de fuerza bruta SSH
monitorizado con Wazuh SIEM

AUTOR

Bryan Acanda Gonzalez

BOOTCAMP

Ciberseguridad — Neoland

FECHA

2026-09-24

ENFOQUE

Blue Team / SOC Analyst L1

SIEM

Wazuh 4.14.7 (Manager + Indexer +
Dashboard)

ENTORNO

Laboratorio controlado — red Host-Only
aislada

1. Resumen ejecutivo

Este laboratorio simula un escenario real de ataque de fuerza bruta SSH contra un servidor Ubuntu expuesto, monitorizando todo el proceso con Wazuh como SIEM. El ejercicio se divide en dos fases diferenciadas:

Fase ofensiva (Ataque 1): Desde una máquina Kali Linux se lanzó un ataque de fuerza bruta automatizado con Hydra contra el usuario `soclab`. El ataque tuvo éxito — se obtuvieron las credenciales válidas y se estableció una sesión interactiva en el servidor. Wazuh detectó y registró todo el incidente, generando una alerta de correlación de nivel 12.

Fase defensiva (Ataque 2): Se aplicó hardening al servidor (desactivación de autenticación por contraseña, limitación de intentos SSH e instalación de Fail2ban). Al repetir el mismo ataque, Hydra fue bloqueado antes de poder probar una sola contraseña.

El laboratorio demuestra la diferencia crítica entre un servidor desprotegido y uno hardenizado, tanto desde la perspectiva del atacante como desde la del analista SOC.

2. Arquitectura del laboratorio

VM	IP	Sistema	Rol
Kali Linux	192.168.56.102	Kali Linux (rolling)	Atacante / generador de eventos
Ubuntu Server	192.168.56.103	Ubuntu Server 22.04	Objetivo SSH + Wazuh Manager all-in-one

Red: Host-Only aislada (192.168.56.0/24). Sin conectividad externa durante el ataque.

Wazuh: Instalación all-in-one en el mismo Ubuntu Server que actúa como objetivo. El Manager actúa como agente 000, monitorizando la propia máquina.

Usuario objetivo: `soclab` — cuenta de laboratorio con contraseña `soclab123`.

Recolección de logs: Wazuh 4.14.7 en Ubuntu captura los eventos SSH a través de journald (`<log_format>journald</log_format>`), que recoge todo lo que escribe sshd en tiempo real.

3. Herramientas utilizadas

Herramienta	Versión	Uso
Wazuh	4.14.7	SIEM — detección y correlación de eventos
Hydra	9.6	Herramienta de fuerza bruta de red
OpenSSH	—	Servicio SSH objetivo
Fail2ban	—	Bloqueo automático de IPs

4. FASE 1 — Ataque sin hardening

4.1 Estado inicial del servidor

Antes del primer ataque, el servidor Ubuntu presentaba la configuración SSH por defecto:

```
MaxAuthTries    6          # 6 intentos por sesión
PasswordAuthentication yes  # acepta contraseñas
PermitRootLogin  prohibit-password
```

Sin Fail2ban instalado. Sin ningún mecanismo de bloqueo de IPs. El servidor aceptaba intentos de autenticación ilimitados desde cualquier IP.

4.2 Ejecución del ataque

Desde Kali Linux se preparó un diccionario de 11 contraseñas con la contraseña correcta al final:

```
wrongpass1, badpass2, test123, letmein, password,
123456, admin123, qwerty, soclab, soclab1, soclab123
```

Comando ejecutado:

```
hydra -l soclab -P /tmp/passwords.txt ssh://192.168.56.103 -t 4 -V
```

Resultado: Hydra probó todas las contraseñas del diccionario y encontró las credenciales válidas:

```
[22][ssh] host: 192.168.56.103  login: soclab  password: soclab123
```

A continuación se realizó un login manual para confirmar el acceso:

```
ssh soclab@192.168.56.103
# Contraseña: soclab123 → acceso concedido
```

4.3 Detección por Wazuh

Wazuh detectó el ataque completo en tiempo real. Los eventos registrados en el dashboard de Threat Hunting:

Timestamp	Rule ID	Nivel	Descripción
08:48:53 EDT	5760	5	sshd: authentication failed
08:48:53 EDT	5763	10	sshd: brute force trying to get access
08:48:55 EDT	5557	5	unix_chkpwd: Password check failed
08:48:55 EDT	5501	3	PAM: Login session opened
08:48:57 EDT	2502	10	syslog: User missed the password more than one time
08:49:20 EDT	5715	3	sshd: authentication success
08:49:20 EDT	40112	12	Multiple authentication failures followed by a success

4.4 Análisis de la alerta de correlación

La alerta más importante es la regla **40112** (nivel 12 — crítico). Esta regla nativa de Wazuh correlaciona dos patrones:

1. Múltiples fallos de autenticación SSH desde la misma IP en una ventana de tiempo
2. Un login exitoso posterior desde esa misma IP

Esta correlación es exactamente el patrón de un ataque de fuerza bruta exitoso. En un SOC real, una alerta de nivel 12 generaría una notificación inmediata al analista de turno.

4.5 Filtros DQL utilizados en la investigación

```
# Timeline completo del incidente
rule.id: (5760 or 5763 or 5715 or 40112)

# Solo fallos SSH
rule.id: 5760

# Login exitoso
rule.id: 5715

# Alerta de correlación
rule.id: 40112
```

4.6 Impacto del Ataque 1

El ataque tuvo éxito. El atacante obtuvo:

- Credenciales válidas del usuario `soclab`
- Sesión interactiva en el servidor Ubuntu
- Acceso a todos los recursos disponibles para ese usuario

En un entorno real, el impacto potencial incluiría acceso a datos sensibles, lateral movement hacia otros sistemas, instalación de backdoors y posible escalada de privilegios.

5. FASE 2 — Hardening del servidor

Tras el primer ataque se aplicaron las siguientes medidas de seguridad:

5.1 Hardening SSH

Se modificó `/etc/ssh/sshd_config`:

```
MaxAuthTries 3          # reducido de 6 a 3 intentos por sesión
PasswordAuthentication no # desactiva completamente el login por contraseña
```

Impacto de `PasswordAuthentication no`: El servidor deja de aceptar contraseñas como método de autenticación. Solo acepta claves SSH. Esto inutiliza completamente Hydra y cualquier herramienta de fuerza bruta de diccionario.

Verificación aplicada:

```
sudo sshd -T | grep -E "maxauthtries|passwordauthentication"
# maxauthtries 3
# passwordauthentication no
```

5.2 Configuración de acceso por clave SSH

Para no perder el acceso al servidor tras desactivar la autenticación por contraseña, se generó un par de claves SSH en Kali y se copió la clave pública al servidor:

```
ssh-keygen -t ed25519 -f ~/.ssh/id_ed25519 -N ""
ssh-copy-id kali@192.168.56.103
```

5.3 Instalación y configuración de Fail2ban

```
sudo apt install fail2ban -y
```

Configuración en `/etc/fail2ban/jail.local`:

```
[sshd]
enabled = true
port = ssh
maxretry = 3
findtime = 60
bantime = 300
```

- `maxretry 3` — banea la IP tras 3 intentos fallidos

- `findtime 60` — ventana de 60 segundos para contar los intentos
- `bantime 300` — la IP queda bloqueada 5 minutos

Papel de Fail2ban como segunda capa: Con `PasswordAuthentication no` ya activo, Hydra es bloqueado en la negociación del protocolo SSH antes de generar intentos de autenticación. Fail2ban actúa como segunda línea de defensa para escenarios donde el hardening SSH no es suficiente: ataques con claves SSH, intentos de reconocimiento masivos o si la configuración SSH se revierte accidentalmente.

6. FASE 3 — Segundo ataque (servidor hardenizado)

6.1 Ejecución del mismo ataque

Mismo comando, mismo diccionario:

```
hydra -l soclab -P /tmp/passwords.txt ssh://192.168.56.103 -t 4 -V
```

Resultado:

```
[ERROR] target ssh://192.168.56.103:22/ does not support password authentication (method reply 4).
```

Hydra no pudo probar ninguna contraseña. El servidor rechazó el ataque en la fase de negociación del protocolo SSH, antes de que se procesara un solo intento de autenticación.

6.2 Rastro en Wazuh

Al revisar el dashboard de Wazuh tras el segundo ataque: **ninguna alerta SSH generada**. El hardening cortó el ataque tan temprano que ni siquiera llegó a producir eventos de autenticación que el SIEM pudiera registrar.

7. Regla personalizada 100010

Además de las reglas nativas de Wazuh, se escribió una regla de correlación personalizada que replica y amplía la detección de la regla 40112.

7.1 Archivo: `/var/ossec/etc/rules/local_rules.xml`

```
<group name="local,sshd,">
  <rule id="100010" level="12" frequency="10" timeframe="300">
    <if_matched_sid>5760</if_matched_sid>
    <same_source_ip />
    <if_sid>5715</if_sid>
    <description>Multiple SSH authentication failures followed by a successful login - possible brute force attack.</description>
    <mitre>
      <id>T1110.001</id>
      <id>T1078</id>
    </mitre>
    <group>authentication_failures,pci_dss_10.2.4,pci_dss_10.2.5,</group>
  </rule>
</group>
```

7.2 Lógica de la regla

Parámetro	Valor	Significado
id	100010	ID único — los personalizados empiezan en 100000
level	12	Criticidad máxima (escala 0-15)
frequency	10	Requiere 10 ocurrencias del evento padre
timeframe	300	En una ventana de 300 segundos (5 minutos)
if_matched_sid	5760	Evento padre: fallo de autenticación SSH
if_sid	5715	Evento disparador: login exitoso
same_source_ip	—	Todo desde la misma IP origen

Flujo de detección: Cuando Wazuh recibe un evento de tipo 5715 (login exitoso), comprueba si desde la misma IP, en los últimos 300 segundos, se han producido 10 o más eventos 5760 (fallos de autenticación). Si se cumple la condición, dispara la alerta 100010 de nivel 12.

7.3 Mapeo MITRE ATT&CK en la regla

La regla etiqueta automáticamente las alertas con:

- **T1110.001 — Password Guessing:** los fallos repetidos son intentos de adivinación de contraseña
- **T1078 — Valid Accounts:** el login exitoso confirma uso de credenciales válidas comprometidas

8. Mapeo MITRE ATT&CK completo

Táctica	Técnica	Subtécnica	Evidencia	Reglas Wazuh
Credential Access	T1110 — Brute Force	T1110.001 — Password Guessing	11 fallos SSH en secuencia desde 192.168.56.102	5760, 5763, 2502
Initial Access	T1078 — Valid Accounts	—	Login exitoso con soclab tras el ataque	5715, 40112, 100010

Cadena de ataque

```
[Reconocimiento implícito – usuario soclab conocido]
↓
[T1110.001] Hydra prueba 10 contraseñas incorrectas
↓
[Detección] rule:5763 nivel 10 – fuerza bruta detectada
↓
[T1078] Hydra encuentra soclab123 – login exitoso
↓
[Correlación] rule:40112 / rule:100010 nivel 12 – ALERTA CRÍTICA
```

9. Tabla comparativa — Ataque 1 vs Ataque 2

Criterio	Ataque 1 (sin hardening)	Ataque 2 (con hardening)
PasswordAuthentication	yes	no
MaxAuthTries	6	3
Fail2ban	No instalado	Instalado y activo
Hydra pudo atacar	Sí	No (method reply 4)
Contraseña encontrada	Sí (soclab123)	No
Login exitoso	Sí	No
Alertas en Wazuh	5760, 5763, 5715, 40112	Ninguna
Nivel máximo de alerta	12 — Crítico	—
Impacto	Acceso completo al servidor	Ataque bloqueado

10. Reglas Wazuh utilizadas

Rule ID	Nivel	Descripción	Umbral
5760	5	sshd: authentication failed	Evento individual
5557	5	unix_chkpwd: Password check failed	Evento individual
5503	5	PAM: User login failed	Evento individual
5763	10	sshd: brute force trying to get access	8 eventos / misma IP
2502	10	syslog: User missed the password more than one time	Varios fallos
5715	3	sshd: authentication success	Evento individual
5501	3	PAM: Login session opened	Evento individual
40112	12	Multiple authentication failures followed by a success	Nativa Wazuh
100010	12	Multiple SSH failures followed by success (custom)	10 fallos / 300s + éxito

11. Recomendaciones

Prioridad	Control	Tipo	Técnica mitigada
Alta	PasswordAuthentication no en sshd_config	Preventivo	T1110, T1110.001
Alta	Autenticación exclusiva por clave SSH	Preventivo	T1110.001
Alta	Fail2ban con umbral bajo (3 intentos)	Preventivo	T1110
Media	MFA o acceso SSH vía VPN/bastion host	Preventivo	T1110, T1078
Media	Alertas en tiempo real para nivel ≥ 10	Detective	—
Media	Rotación periódica de claves SSH	Preventivo	T1078
Baja	Cambiar puerto SSH del 22 al estándar no predecible	Preventivo	T1110
Baja	Auditar <code>~/.ssh/authorized_keys</code> periódicamente	Detective	T1078

12. Conclusiones

Este laboratorio demuestra de forma práctica el ciclo completo de un incidente de seguridad: ataque, detección, análisis y respuesta.

Sobre la detección: Wazuh es capaz de detectar un ataque de fuerza bruta SSH en tiempo real, correlacionar los eventos y generar una alerta de nivel crítico. La regla personalizada 100010 amplía la detección nativa con un umbral configurable y mapeo MITRE ATT&CK automático.

Sobre la prevención: Una sola medida — desactivar la autenticación por contraseña — es suficiente para inutilizar completamente Hydra y cualquier herramienta de fuerza bruta de diccionario. La defensa en profundidad (SSH hardening + Fail2ban) añade capas adicionales de protección.

Lección principal: Detectar no es suficiente — hay que prevenir. El SIEM proporciona visibilidad total del ataque, pero sin hardening solo estás observando cómo comprometen el servidor. La combinación de ambos es lo que define una postura de seguridad real.

Habilidades demostradas:

- Instalación y configuración de Wazuh SIEM (all-in-one)
- Uso de Hydra para simulación de ataques de fuerza bruta
- Investigación de incidentes y construcción de timelines en Wazuh
- Hardening de SSH en Ubuntu
- Configuración de Fail2ban
- Escritura de reglas de correlación personalizadas en Wazuh
- Mapeo de técnicas a MITRE ATT&CK
- Redacción de informe de incidente

13. Evidencias

ID	Descripción	Archivo
EV-01	Fallos SSH detectados en Threat Hunting — rule 5760	evidencias/01-failed-attempts.png
EV-02	Detalle del evento — srcip, dstuser, full_log	evidencias/02-source-ip.png
EV-03	Dashboard overview — alertas generadas	evidencias/03-dashboard-overview.png
EV-04	MITRE ATT&CK dashboard — T1110.001 + T1078	evidencias/04-mitre-attack.png
EV-05	Alerta de correlación nivel 12 — rule 40112	evidencias/05-brute-force-detection.png
EV-06	Regla personalizada 100010	detecciones/local_rules.xml
EV-07	Mapeo MITRE ATT&CK completo	detecciones/mitre_attack_mapping.md

Laboratorio realizado en entorno controlado sobre sistemas propios. Red Host-Only aislada sin conectividad externa. Todos los ataques se ejecutaron exclusivamente sobre máquinas virtuales propiedad del autor.

Bryan Acanda Gonzalez — Bootcamp Ciberseguridad, Neoland — 2026-09-24